

RAG-Augmented Multi-Agent LLM Framework for Explainable Software Vulnerability Detection Using CWE Knowledge Bases

Richa Verma (25MCSS02) Advisor: Dr. Akshay Pandey

What we want the tool to explain

Where this fits

Many scanners only say that a piece of code is unsafe. The programmer still has to guess the kind of mistake and the fix.

This note explains the problem we are working on. Later notes will describe the files, the knowledge book, the search, and the scores. Those pieces are not built in this note.

What we did

We want a tool that reads a short Java method and writes a note a person can check.

The note should say four things: whether the code is unsafe, which weakness it is, which lines matter, and how to fix it.

The weakness name comes from CWE. CWE is a public list of common software mistakes. We use the official name so two people mean the same thing.

We are studying six Java weaknesses only. They are listed in the table. They cover database queries, web pages, file paths, saved objects, passwords in code, and weak encryption.

We are not trying to replace a commercial scanner. The aim is an explanation that can be traced back to a CWE page and to real lines of code.

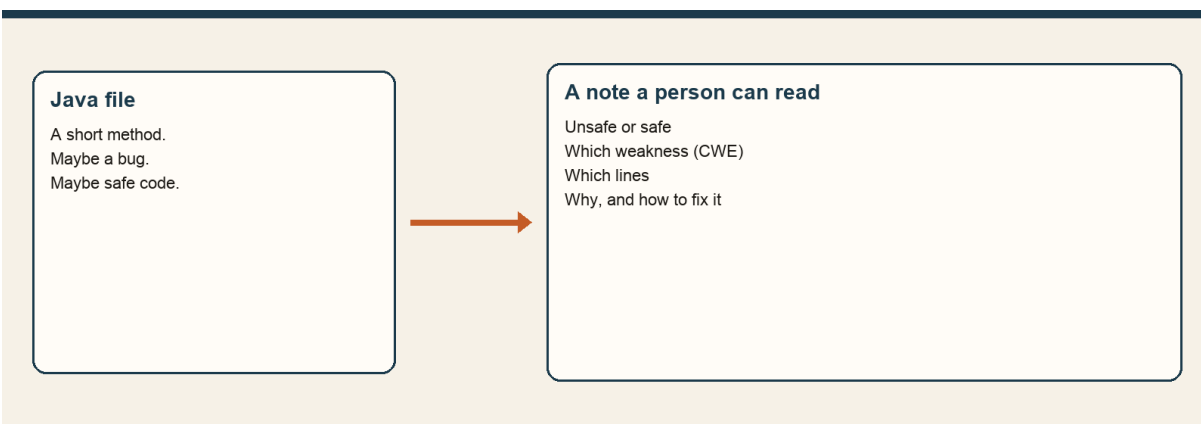
A concrete example

Suppose a method builds a database query by joining a username onto the text of the query. A yes-or-no scanner might only say "unsafe".

The note we want is longer. It should say the code is unsafe, the weakness is CWE-89 SQL injection, the risky lines are the ones that build the query, and the fix is to use a prepared query so the username is data, not part of the command.

If the same method uses a prepared query, the note should say the code is safe, and it should still name CWE-89 so a reader knows which risk was checked.

Picture



The left box is the Java we read. The right box is the note we want back.

The numbers

Weakness	Plain meaning
CWE-89	SQL injection. User text is stuck into a database query.
CWE-79	Cross-site scripting. User text is shown as part of a web page.
CWE-22	A file path can be steered outside the intended folder.
CWE-502	Loading a saved object can run attacker-controlled data.
CWE-798	A password is written directly in the code.
CWE-327	The code uses weak encryption or a weak hash.

These six are the whole scope. A different kind of bug is outside this project, and we will not relabel it to force a match.

Closing

The next piece of work is a small set of Java examples, half unsafe and half safe, so the idea can be tried on real files.

Until those files exist, there is nothing to score.

What we are not saying

This note has no test scores. It does not say the tool is better than any other scanner.